

EXPOSITORES

Capriotti, Santiago

Carovana, Leonel

Cardone, Juan Ignacio

Cosentino, Lucio

Donzino, Yamila

Duarte, Lautaro

Tanchi, Candela

RANSOMWARE

Secuestro de datos, extorsión y respuesta

Seguridad de la Información

Universidad Tecnológica Nacional — Facultad Regional Rosario

Catedra: Ing. Mariano Lancioni | 18 de septiembre de 2026

Agenda

01 Introducción y panorama global

02 Cómo funciona: kill chain y criptografía

03 Tipos, doble extorsión y modelo RaaS

04 Vectores de acceso inicial

05 Casos internacionales

06 LockBit y casos en Argentina

07 Mitigación, respuesta y cierre

¿Qué es el ransomware?



Malware que cifra o bloquea los datos de la víctima y exige un pago (rescate) a cambio de la clave de descifrado.

Tres puntos que lo hacen único frente a otros malware

Malware es cualquier software diseñado para causar daño, robar información o tomar control de un sistema sin consentimiento del usuario.

Cifrado fuerte

AES-256 para datos, RSA-2048/4096 para proteger la clave.

Pago en criptomonedas

BTC o Monero, difícil de trazar.

Presión temporal

Cuenta regresiva, aumento del rescate, filtración.

Escala del problema en 2025

USD 1,53M

Costo promedio de recuperación (excl. rescate)

57%

de rescates supero USD 1M

49%

de víctimas pago

97%

recupero datos cifrados

Argentina | contexto local

5.700 M

intentos de ciberataque en 2025

260 M

intentos solo en el 1er trimestre 2024

Salud y gobierno

sectores más golpeados en LATAM 2025 (ESET)

Cadena de ataque: 7 fases



Reconocimiento

1 OSINT, escaneo, listado de expuestos.



Acceso inicial

2 Phishing, RDP, VPN, vuln explotada.



Ejecución

3 Loader/dropper, macros, LOLBins.



Persistencia + escalada

4 Servicios, tareas, credenciales de dominio.



Movimiento lateral

5 SMB, PsExec, RDP interno, C&C.



Exfiltración

6 Rclone / MegaSync a nube atacante.



Cifrado + nota

7 AES por archivo, borrado de shadow copies.

Criptografía híbrida: AES + RSA

¿Por qué híbrido?

AES-256 (simétrico)

Rápido. Cifra los archivos de la víctima uno por uno.

RSA-2048 / 4096 (asimétrico)

Lento pero irreversible sin la clave privada. Cifra la clave AES.

Resultado

Sin la clave privada RSA (que tiene el atacante) no hay descifrado posible en tiempo razonable.

Flujo simplificado

1. Se genera una clave AES-256 única por sesión.

2. AES cifra cada archivo (.docx, .xlsx, .sql, etc.).

3. La clave AES se cifra con la RSA pública del atacante.

4. El bloque cifrado queda dentro del archivo o de la nota de rescate.

La nota de rescate

●●● README_FOR_DECRYPT.txt

>>> LOCKBIT 3.0 <<<

All your important files have been encrypted.
Your unique ID: 8A73F...B21E

PRICE: 850,000 USD in Monero (XMR)
DEADLINE: 72 hours. Price x2 after.

> DO NOT rename encrypted files.
> DO NOT try third-party tools.
> Contact us via TOR:
<http://lockbit...onion>

Files are also uploaded to our leak site.
Non-payment = public disclosure.

Elementos comunes

● ID único

Correlaciona víctima con clave privada.

● Precio

Monero preferido, Bitcoin en menos casos.

● Deadline

72 h suele duplicar el precio.

● Canal TOR

Chat de negociación privado.

● Amenaza de leak

Sitio público con archivos exfiltrados.

Tipos de ransomware



Crypto ransomware

Cifra archivos. El sistema sigue funcionando, los datos no.

Ejemplos: LockBit, Conti, Ryuk



Locker ransomware

Bloquea el acceso al sistema completo (pantalla o boot).

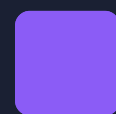
Ejemplos: WinLocker, Reveton



Doxware / Leakware

Amenaza con publicar información sensible robada.

Ejemplos: Maze, DoppelPaymer



Wiper (falso ransomware)

Destruye datos, no hay clave real de recuperación.

Ejemplos: NotPetya, HermeticWiper



RaaS (modelo de negocio)

Plataforma alquilada a afiliados con soporte 24/7.

Ejemplos: LockBit, BlackCat, Cl0p



Mobile ransomware

Bloquea Android/iOS o cifra almacenamiento externo.

Ejemplos: Simplotter, Filecoder.C

Evolución de la extorsion

1x

Extorsión simple

Cifrar y pedir rescate por descifrar.

2015+

2x

Doble extorsión

Cifrar + amenaza de publicar datos robados.

2019+ (Maze)

3x

Triple extorsión

+ DDoS contra la víctima si no paga.

2020+ (SunCrypt)

4x

Cuadruple extorsión

+ Contacto directo a clientes, socios y prensa.

2021+ (REvil, Cl0p)

Hoy, la mayoría de los grupos combinan varias capas. Pagar la clave no garantiza que los datos no salgan igual a la venta.

Ransomware-as-a-Service (RaaS)

¿Qué es?

Modelo empresarial de ciberdelincuencia: un grupo desarrolla el ransomware y su infraestructura, otros lo alquilan como afiliados.

Reparto típico 70% afiliado / 30% operador.

*El atacante ya no necesita saber programar.
Solo necesita acceso.*

Roles en un ecosistema RaaS

Operador / Desarrollador

Mantiene el código, panel, sitio de leak y negociación.

Afiliado (Affiliate)

Compromete a la víctima y despliega el ransomware.

Initial Access Broker (IAB)

Vende accesos ya obtenidos (RDP, VPN, credenciales).

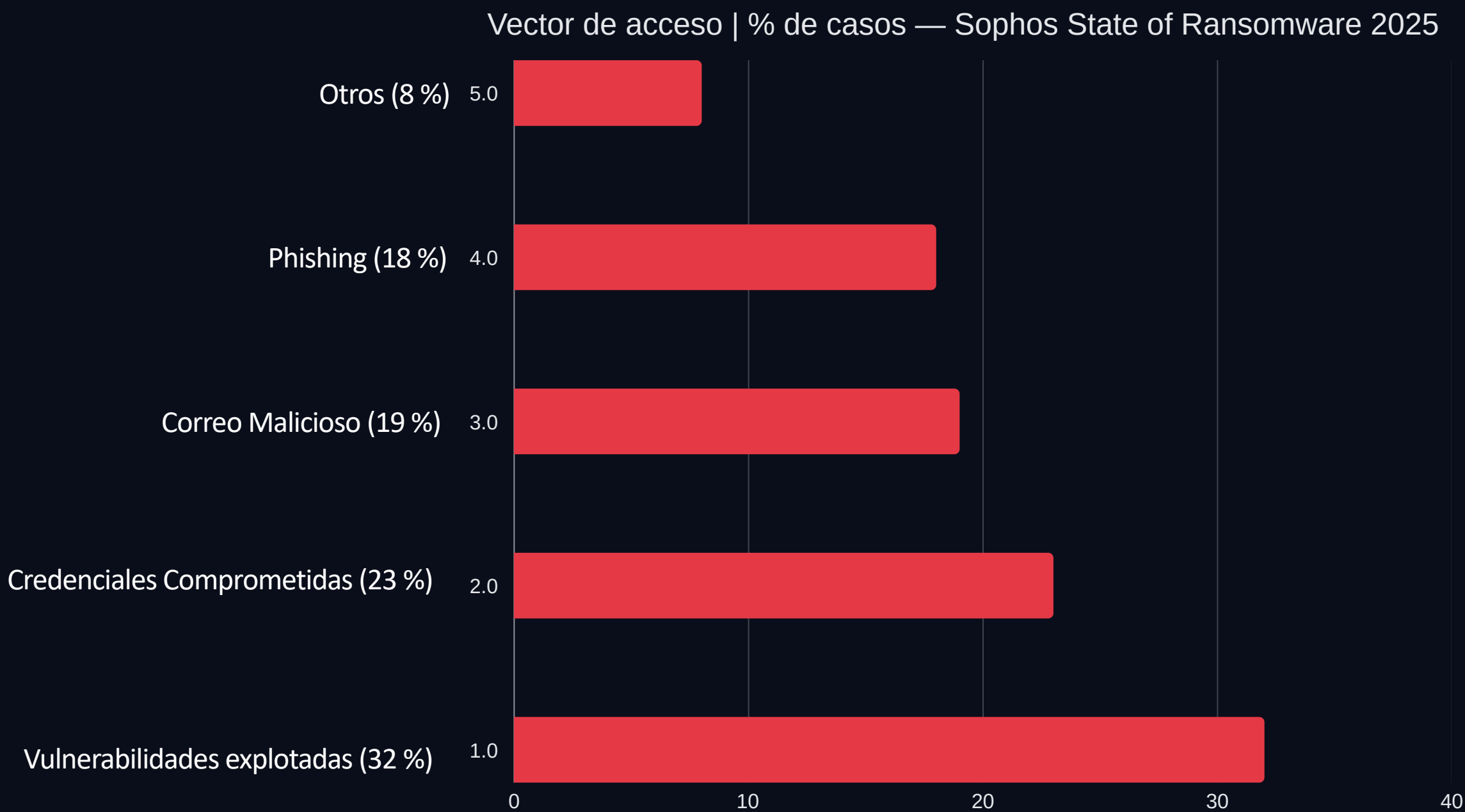
Negociador

Interlocutor con la víctima. Ajusta precio y plazo.

Lavador de cripto

Mezcla los fondos, los convierte a fiat.

Vectores de acceso inicial



Lectura clave

55%

de los ataques usa un problema técnico corregible (parche o MFA).

37%

combina ingeniería social (phishing + correos maliciosos).

Vulnerabilidades explotadas

CVE-2017-0144

Windows

EternalBlue (SMBv1)

Ejecución remota. Usada por WannaCry, NotPetya, Ryuk.

CVE-2019-19781

Citrix

Citrix ADC / Gateway

Path traversal. Explotada masivamente por Sodinokibi.

CVE-2021-34527

Windows

PrintNightmare

Escalada de privilegios via spooler. Uso post-explotación.

CVE-2023-34362

Progress

MOVEit Transfer

Inyección SQL. ClOp comprometio 2.700+ organizaciones.

CVE-2024-1709

ConnectWise

ScreenConnect

Bypass auth. Usada por Black Basta y BlackSuit.

RDP expuesto

Windows Server

Puerto 3389 abierto

Fuerza bruta y credenciales débiles. Vector histórico.

WannaCry — mayo de 2017

Contexto

Gusano-ransomware que se autopropaga por SMBv1 usando el exploit **EternalBlue** (CVE-2017-0144), filtrado por Shadow Brokers desde la NSA. Atribuido al grupo Lazarus (RPDC).

Kill switch

Marcus Hutchins registro el dominio hardcodeado del malware (iuqerfsodp9...com), lo que detuvo la ola inicial en horas.

230.000+

equipos infectados en 1 día

150

países afectados

USD 300

rescate inicial (Bitcoin)

USD 4 mil M

danio económico estimado

NHS UK

1/3 de hospitales, ambulancias desviadas

Telefónica

ES, primera gran corporativa golpeada

Colonial Pipeline — mayo de 2021

Contexto

Grupo **DarkSide** (RaaS de Europa del Este) comprometió una cuenta VPN legacy sin MFA. Colonial paro el 100% de la operación por precaución, no por cifrado del OT.

Consecuencias

- Emergencia federal en 17 estados de EEUU.
- Panic buying, escasez de nafta en la costa este.
- FBI recuperó USD 2,3M del rescate (Chainalysis).

USD 4,4 M

rescate pagado en Bitcoin

6 días

operación detenida (7-12 mayo)

8.850 km

de ductos afectados (~5.500 mi)

45%

del combustible de la costa este

100 GB

de datos exfiltrados (doble extorsión)

MFA

ausente en la cuenta VPN comprometida

Change Healthcare — febrero de 2024

Contexto

ALPHV / BlackCat accedió via un portal Citrix sin MFA el 12/02, desplego ransomware el 21/02. Change Healthcare procesa 15 mil millones de transacciones médicas al año en EEUU: un tercio de los registros del país.

Impacto sistémico

- 77% de clínicos con interrupción de servicios.
- 55% de dueños de consultorio pagaron con fondos propios.
- Farmacias sin poder validar recetas por semanas.

USD 22 M

rescate pagado en Bitcoin

USD 872 M

pérdida reportada por UnitedHealth

USD 1.000+ M

impacto total proyectado

100 M

personas con datos comprometidos

Citrix

acceso inicial vía cuenta sin MFA

24

class actions consolidadas

LockBit y Operation Cronos — febrero de 2024

El grupo mas prolífico de la década

LockBit operaba bajo modelo RaaS. Segun la NCA (UK), fue responsable del **25% de los ataques de ransomware globales entre 2023 y 2024**. Víctimas incluyeron a Boeing, ICBC (banco mas grande del mundo por activos), TSMC, Royal Mail y Aguas Bonaerenses.

Operation Cronos (19 feb 2024)

10 países coordinados (NCA UK + FBI + Europol + otros). Toma del panel, sitio de leaks, código fuente y datos de 194 afiliados. Detenidos en Polonia y Ucrania.

Timeline breve



Argentina: Migraciones — agosto 2020

¿Qué pasó?

El ransomware **Netwalker** cifró los sistemas de la Dirección Nacional de Migraciones. El sistema SiCaM (control migratorio en fronteras) quedó fuera de servicio todo el día, provocando demoras en pasos internacionales.

Respuesta oficial

- Argentina NO pagó el rescate.
- Restauración desde backups.
- Netwalker público ~1,8 GB en la dark web.

USD 4 M

rescate solicitado

USD 2 M

monto inicial

25.723

argentinos repatriados afectados

1,8 GB

publicados en leak site

7 días

plazo hasta publicación

SiCaM

sistema de fronteras caído 1 día

Argentina: cronología 2020 — 2025

Año	Organización	Grupo atacante	Sector
2020	Migraciones	Netwalker	Gobierno nacional
2022	Senado de la Nación	n/d	Gobierno nacional
2023	Grupo Albanesi	LockBit	Energía
2023	CNV	Medusa	Regulador financiero
2023	INTA	n/d	Científico-técnico
2023	Justicia de Córdoba	n/d	Poder judicial
2024	Telecentro	Akira	Telecomunicaciones
2024	Osde / Medifé	n/d	Salud (prepagas)
2024	RENAPER (dato)	n/d	Documentos (65M reg.)
2025	Fabricaciones Militares	Monti	Defensa
2025	CNEA	n/d	Energía atómica
2025	Legislatura Chaco	n/d	Legislativo provincial

Fuente: Cumplimiento Digital + Ciberseguridad Argentina (2026).

Prevención: defensa en profundidad

1 Perímetro

- Firewall + IDS/IPS
- MFA obligatorio en VPN y RDP
- Cerrar puertos innecesarios (3389, 445)

2 Identidad

- MFA en todos los usuarios
- Políticas de contraseñas fuertes
- Least privilege + rotación de admin

3 Endpoint

- EDR / XDR con respuesta automática
- Application allowlisting
- Deshabilitar macros por default

4 Datos y backup

- Backup 3-2-1-1-0 (siguiente slide)
- Cifrado en reposo y en tránsito
- Segmentación de red por criticidad

5 Personas

- Simulaciones de phishing periódicas
- Capacitación en ingeniería social
- Canal claro para reportar sospechas

6 Proceso

- Plan de respuesta a incidentes (IR)
- Gestión de parches priorizada
- Tabletop exercises anuales

Regla 3-2-1-1-0 de backup

3

Copias

Datos originales + 2 copias adicionales.

2

Medios

Al menos 2 tipos de soporte distintos (disco, cinta, nube).

1

Off-site

Una copia fuera del sitio principal.

1

Offline / air-gapped

Una copia desconectada e inaccesible por red.

0

Errores

Cero errores tras verificación y prueba de restauración.

La copia offline es la que el atacante NO puede cifrar. Sin ella, todo backup es discutible.

Detección y respuesta (IR)

Detección

● EDR / XDR

Bloqueo de comportamiento anómalo, no solo firmas.

● SIEM + SOC 24/7

Correlación de eventos y respuesta humana.

● Honeypots / canarios

Archivos trampa que alertan si son tocados.

● UEBA

Detección de acceso a archivos fuera de patrón.

● Threat intel

IOCs actualizados (LockBit, Akira, RansomHub).

Respuesta a incidentes (NIST 800-61)

1

Preparación

IR plan, roles, contactos, retainer forense.

2

Detección + análisis

Determinar alcance y familia.

3

Contención

Aislar segmentos, cortar C&C, revocar sesiones.

4

Erradicación

Remover persistencia, rotar credenciales.

5

Recuperación

Restaurar desde backup validado.

6

Lecciones aprendidas

Postmortem sin buscar culpables.

¿Pagar o no pagar?

A favor de pagar

- Recuperación más rápida si no hay backups viables.
- Menor costo directo que la reconstrucción.
- Reduce (no elimina) el riesgo de leak público.

Contra el pago

- Financia al crimen organizado.
- No garantiza clave funcional (Kaspersky: ~8% no recupera).
- Puede violar sanciones OFAC (multas y penal).
- El 78% de quienes pagan son atacados de nuevo (Cybereason).

Recomendación CISA / FBI / ENISA: no pagar. Reportar, contener, restaurar desde backup verificado. Involucrar autoridades y aseguradora antes de negociar.

Conclusiones

01

Es una industria, no un truco técnico

RaaS profesionalizo el ecosistema. Hay soporte, negociadores y afiliados.

02

Casi todo se entra por lo mismo

Credenciales sin MFA, phishing y vulnerabilidades sin parche cubren >70%.

03

El cifrado es lo último que pasa

Antes hubo días de acceso, exfiltración y borrado de backups.

04

El backup 3-2-1-1-0 es el seguro real

Sin copia offline verificada, la organización depende del atacante.

05

Pagar no es una estrategia

Financia al problema, no garantiza recuperación y expone a sanciones.

06

La respuesta se prepara antes

Un IR plan probado es lo que separa horas de meses de recuperación.

FIN DE LA EXPOSICIÓN

¿PREGUNTAS?

Gracias por su atención.

Grupo Ransomware

Capriotti, Santiago · Cardone, Juan Ignacio · Carovana, Leonel · Cosentino, Lucio · Donzino, Yamila · Duarte, Lautaro · Tanchi, Candela